

OWASP Top 10 (Summary)

Broken Access Control: Enforce server-side authorization, least privilege.

Cryptographic Failures: Use strong encryption, TLS, avoid hardcoded secrets.

Injection: Use parameterized queries, validate inputs, avoid string concatenation.

Insecure Design: Apply secure-by-design principles and threat modeling.

Security Misconfiguration: Disable defaults, patch systems, secure headers.

Vulnerable Components: Keep dependencies updated and scan regularly.

Authentication Failures: Use MFA, secure password storage, session management.

Software/Data Integrity Failures: Verify updates, signed code, CI/CD integrity.

Logging & Monitoring: Log security events and monitor for incidents.

SSRF: Restrict outbound requests, validate destinations.